

WIRESHARK: ESTRAZIONE DI UN ESEGUIBILE DA UN PCAP

1. Analisi del flusso TCP

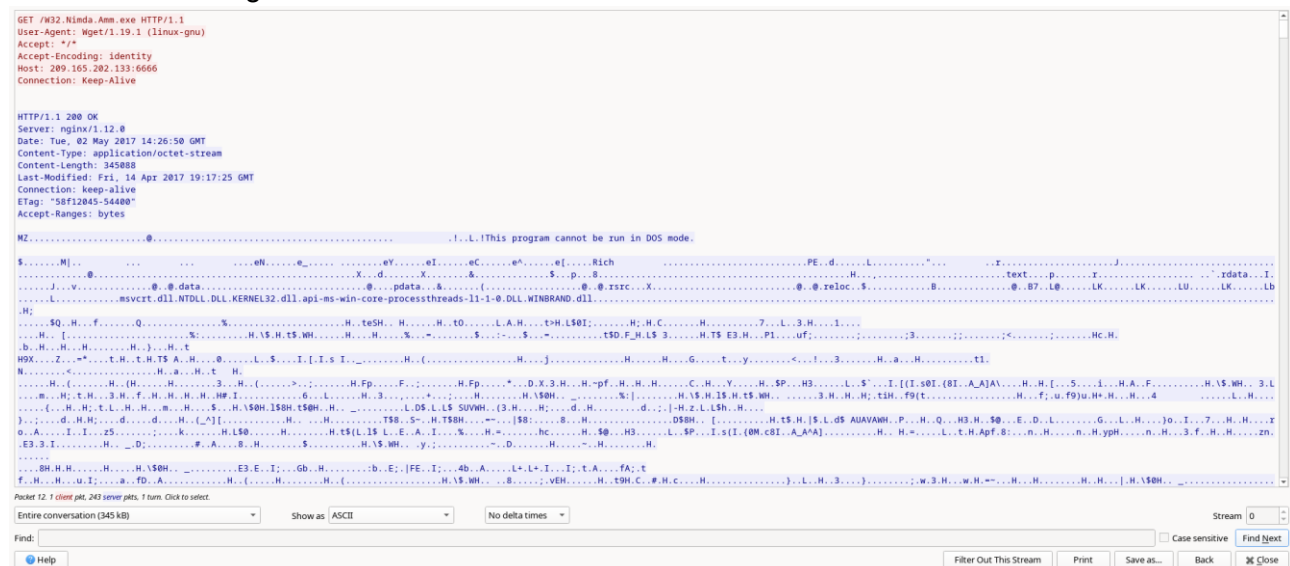
La cattura mostra una richiesta HTTP *GET* del file *W32.Nimda.Amm.exe* inviata all'host 209.165.202.133 sulla porta 6666.

No.	Time	Source	Destination	Protocol	Length	Info
1	14:26:58.686388	209.165.200.235	209.165.202.133	TCP	74	48598 → 6666 [SYN] Seq=0 Win=29200 Len=0 MSS=1460 SACK_PERM TSval=4051203246 TSecr=0 WS=512
2	14:26:58.686647	209.165.202.133	209.165.200.235	TCP	74	6666 → 48598 [SYN, ACK] Seq=0 Ack=1 Win=29060 Len=0 MSS=1460 SACK_PERM TSval=4051203246 TSecr=4051203246 WS=512
3	14:26:58.686685	209.165.200.235	209.165.202.133	TCP	66	48598 → 6666 [ACK] Seq=1 Ack=1 Win=29060 Len=0 TSval=4051203246 TSecr=3023496465
4	14:26:58.686923	209.165.200.235	209.165.202.133	HTTP	274	GET /W32.Nimda.Amm.exe HTTP/1.1
5	14:26:58.686976	209.165.202.133	209.165.200.235	TCP	60	6666 → 48598 [ACK] Seq=1 Ack=105 Win=30200 Len=0 TSval=3023496465 TSecr=4051203246
6	14:26:58.687096	209.165.202.133	209.165.200.235	TCP	324	6666 → 48598 [PSH, ACK] Seq=1 Ack=105 Win=30200 Len=258 TSval=3023496465 TSecr=4051203246 [TCP PDU reassembled in 309]
7	14:26:58.687215	209.165.200.235	209.165.202.133	TCP	66	48598 → 6666 [ACK] Seq=105 Ack=259 Win=30720 Len=0 TSval=4051203246 TSecr=3023496465
8	14:26:58.689082	209.165.202.133	209.165.200.235	TCP	1514	6666 → 48598 [ACK] Seq=259 Ack=105 Win=30200 Len=1448 TSval=3023496466 TSecr=4051203246 [TCP PDU reassembled in 309]
9	14:26:58.689098	209.165.200.235	209.165.202.133	TCP	66	48598 → 6666 [ACK] Seq=105 Ack=1787 Win=33280 Len=0 TSval=4051203247 TSecr=3023496466
10	14:26:58.689093	209.165.202.133	209.165.200.235	TCP	1514	6666 → 48598 [ACK] Seq=1787 Ack=105 Win=30200 Len=1448 TSval=3023496466 TSecr=4051203246 [TCP PDU reassembled in 309]
11	14:26:58.689098	209.165.200.235	209.165.202.133	TCP	66	48598 → 6666 [ACK] Seq=105 Ack=3155 Win=30352 Len=0 TSval=4051203247 TSecr=3023496466
12	14:26:58.689099	209.165.202.133	209.165.200.235	TCP	1514	6666 → 48598 [ACK] Seq=3155 Ack=105 Win=30200 Len=1448 TSval=3023496466 TSecr=4051203246 [TCP PDU reassembled in 309]
13	14:26:58.691000	209.165.200.235	209.165.202.133	TCP	66	48598 → 6666 [ACK] Seq=105 Ack=4083 Win=30424 Len=0 TSval=4051203247 TSecr=3023496466
14	14:26:58.691001	209.165.202.133	209.165.200.235	TCP	1514	6666 → 48598 [ACK] Seq=4083 Ack=105 Win=30200 Len=1448 TSval=3023496466 TSecr=4051203246 [TCP PDU reassembled in 309]

1 - Sopra: richiesta HTTP *GET* del file *W32.Nimda.Amm.exe* visualizzata in Wireshark.

Cosa sono tutti quei simboli mostrati nella finestra Follow TCP Stream? Sono rumore di connessione? Dati? Spiega. Ci sono alcune parole leggibili sparse tra i simboli. Perché sono lì?

I simboli non sono rumore di connessione, ma rappresentano i dati binari del file eseguibile inviato dal server dopo le intestazioni HTTP. Poiché Wireshark tenta di visualizzarli in formato ASCII, i byte non stampabili appaiono come punti o caratteri apparentemente casuali. Le parole leggibili, come “This program cannot be run in DOS mode” e alcuni nomi di librerie, sono invece stringhe di testo contenute nell'eseguibile.



3 - Sopra: analisi della finestra follow TCP stream.

Domanda Sfida: usando i frammenti di parole visualizzati dalla finestra Follow TCP Stream, puoi dire quale eseguibile sia realmente?

L'eseguibile è in realtà *cmd.exe*. Lo si può identificare dalle stringhe incorporate nel file, tra cui *OriginalFilename: Cmd.Exe*, *InternalName: cmd* e *FileDescription: Windows Command Processor*. Il file è quindi una copia di *cmd.exe* rinominata come *W32.Nimda.Amm.exe*.

```
[analyst@secOps ~]$ ls -l
total 18748
-rw-r--r-- 1 root    root           6433 Sep  1 09:04 capture.pcap
drwxr-xr-x 2 analyst analyst       4096 Sep  7 05:57 Desktop
drwxr-xr-x 3 analyst analyst       4096 Jun 18  2025 Downloads
-rw-r--r-- 1 root    root          46547 Sep  7 05:19 httpdump.pcap
-rw-r--r-- 1 root    root      18760637 Sep  7 05:40 httpsdump.pcap
drwxr-xr-x 9 analyst analyst       4096 Jun 18  2025 lab.support.files
drwxr-xr-x 3 analyst analyst       4096 Jun 18  2025 scripts
drwxr-xr-x 2 analyst analyst       4096 Mar 21  2018 second_drive
-rw-r--r-- 1 analyst analyst        312 Sep  3 08:49 space.txt
-rw-r--r-- 1 analyst analyst     345088 Sep  7 08:22 W32.Nimda.Amm.exe
drwxr-xr-x 5 analyst analyst       4096 Jun 18  2025 yay
```

Pagina 2

Il comando *file* identifica inoltre l'oggetto come un eseguibile PE32+ per Windows, a 64 bit e con sei sezioni.

```
[analyst@secOps ~]$ file W32.Nimda.Amm.exe
W32.Nimda.Amm.exe: PE32+ executable for MS Windows 6.01 (console), x86-64, 6 sections
```

5 - Sopra: identificazione dell'oggetto come eseguibile PE32+ per Windows mediante il comando *file*.

3. Passo successivo dell'analisi

Nel processo di analisi del malware, quale sarebbe un probabile passo successivo per un analista di sicurezza?

Un probabile passo successivo sarebbe eseguire un'analisi statica del file, estraendo l'hash ed esaminando stringhe, intestazioni PE, sezioni e librerie importate. In seguito si potrebbe effettuare un'analisi dinamica in una sandbox isolata, osservando processi, modifiche al sistema, file creati e comunicazioni di rete.